

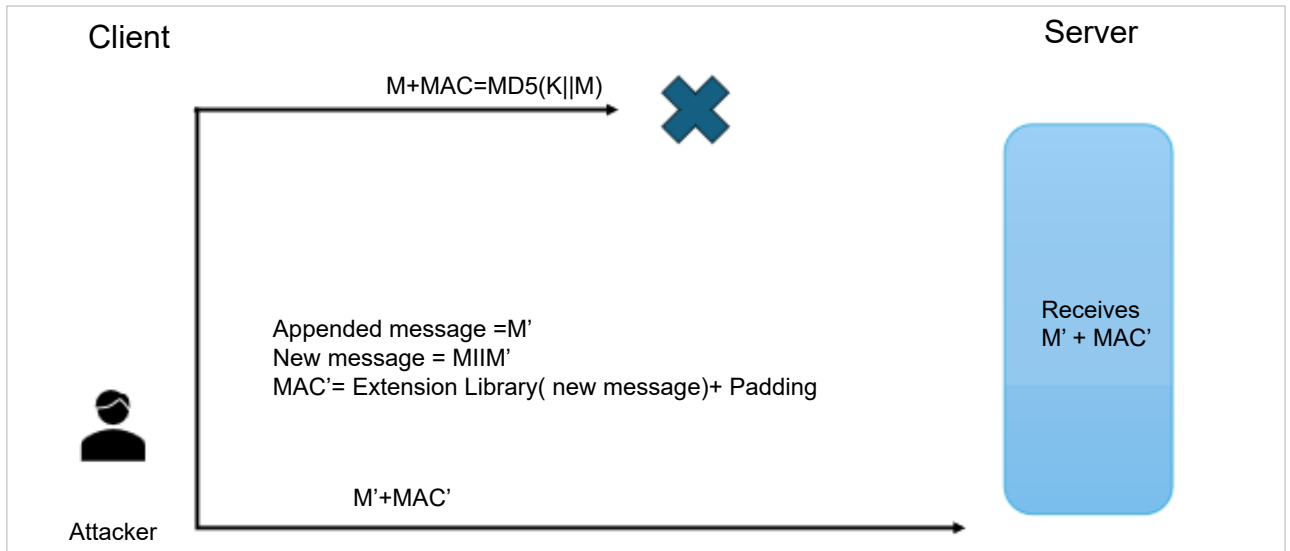


Figure 2: Attacker pathway for length extension attack

SHA-1 to generate key material for the session keys based on the pre-master secret and other handshake information. The handshake involves negotiating cryptographic algorithms and generating session keys. MD5 is used to hash various handshake parameters, including the pre-master secret (PMS), client random(C), and server random(S), to derive the session keys from key material of 128-bit hash value.

Message authentication code (MAC) calculation:

After the handshake and session key are established, MD5 is used to generate the MACs for ensuring data integrity and authenticity of the messages (M) transmitted over the secure connection. The MAC is computed using MD5 and a secret key (K) derived during the handshake. Once the secure connection is established, each message transmitted over the connection is accompanied by a MAC. This MAC is computed using MD5 and a secret key, ensuring that the message has not been tampered with during transmission.

Lack of protection for handshake and message close phase

The SSL 2.0 handshake process is crucial for establishing a secure session. It involves exchanging keys,

agreeing on encryption methods, and authenticating the parties. Proper SSL/TLS implementations ensure that both parties close the connection correctly, confirming that all data has been transmitted securely. However, SSL 2.0 does not adequately protect the handshake or the explicit message close phase. This means that an attacker could intercept and modify messages during these phases without detection. Since the handshake is not fully protected, an attacker could potentially alter the negotiation process (such as choosing a weaker cipher suite to manipulate data easily) or inject malicious data. Similarly, the absence of a secure message close could allow attackers to tamper with or inject additional data into the communication stream. This vulnerability means that attackers could perform man-in-the-middle attacks, intercepting and manipulating the communication between the client and server without the parties being aware.

Length extension attack

Figure 2 depicts how the attacker utilises the potential vulnerability of the MD5 hashing algorithm, which allows the internal state to be extended by appending additional data to the original message. This allows recalculation of MAC even without knowing the secret key used, using libraries allowing one to do so. This processes input in blocks (64-byte blocks).

These vulnerabilities are solely focused on weak integrity checks and have led to the development of the next-generation algorithm, SSL 3.0. This version mitigates the above issues by introducing the 'Finished' message concept, where client and server 'Finished' messages are passed through pseudo-random functions (PRFs) derived from the session key. Additionally, the use of hash-based message authentication code (HMAC) has been introduced, which incorporates hashing along with secret key usage, significantly enhancing security. **END** 🐧

By: Anisha Ghosh

The author is a cybersecurity researcher and an active contributor to open source communities and repositories. She is interested in developing novel, scalable and secure systems.